Day 15: DNS Security Report

What is DNS security?

DNS security is the practice of protecting DNS infrastructure from cyber-attacks in order to keep it performing quickly and reliably. An effective DNS security strategy incorporates a number of overlapping defences, including establishing redundant DNS servers, applying security protocols like DNSSEC, and requiring rigorous DNS logging.

Why is DNS security important?

Like many Internet protocols, the DNS system was not designed with security in mind and contains several design limitations. These limitations, combined with advances in technology, make DNS servers vulnerable to a broad spectrum of attacks, including spoofing, amplification, DoS (Denial of Service), or the interception of private personal information. And since DNS is an integral part of most Internet requests, it can be a prime target for attacks.

In addition, DNS attacks are frequently deployed in conjunction with other cyberattacks to distract security teams from the true target. An organization needs to be able to quickly mitigate DNS attacks so that they are not too busy to handle simultaneous attacks through other vectors.

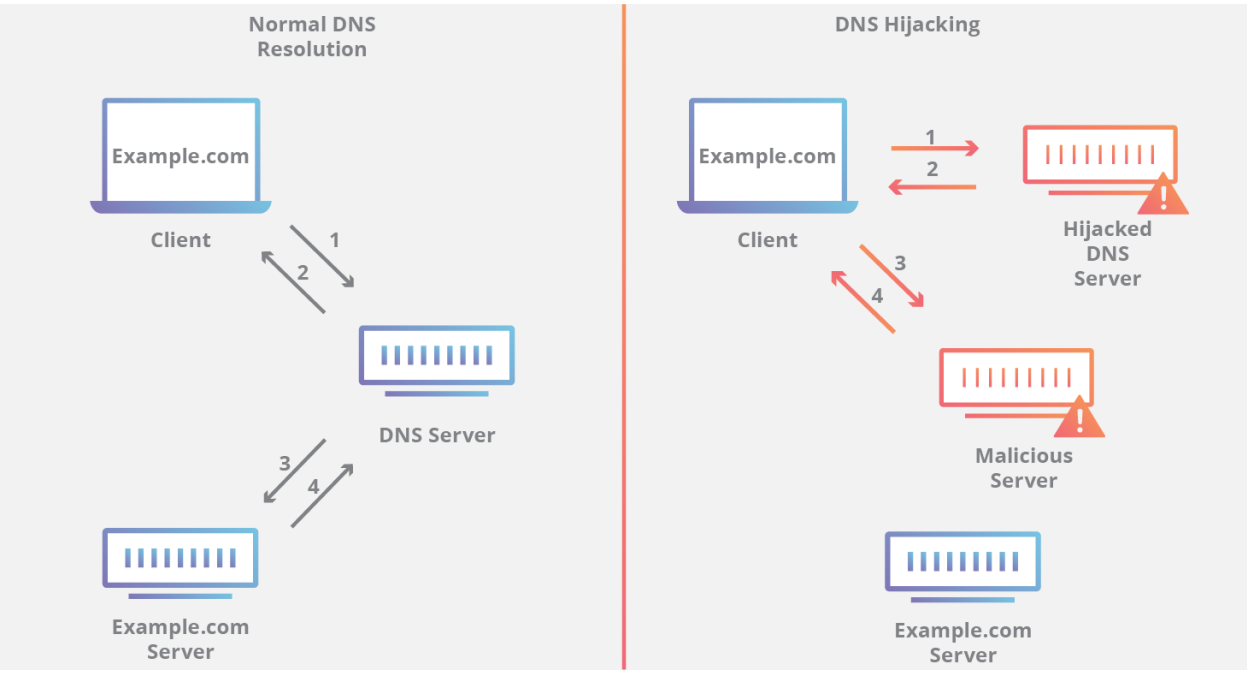
What are some common DNS attacks?

Attackers have found a number of ways to target and exploit DNS servers. Here are some of the most common DNS attacks:

DNS spoofing/cache poisoning: This is an attack where forged DNS data is introduced into a DNS resolver's cache, resulting in the resolver returning an incorrect IP address for a domain. Instead of going to the correct website, traffic can be diverted to a malicious machine or anywhere else the attacker desires; often this will be a replica of the original site used for malicious purposes such as distributing malware or collecting login information.

DNS tunneling: This attack uses other protocols to tunnel through DNS queries and responses. Attackers can use SSH, TCP, or HTTP to pass malware or stolen information into DNS queries, undetected by most firewalls.

DNS hijacking: In DNS hijacking, the attacker redirects queries to a different domain name server. This can be done either with malware or with the unauthorized modification of a DNS server. Although the result is similar to that of DNS spoofing, this is a fundamentally different attack because it targets the DNS record of the website on the nameserver, rather than a resolver's cache.



NXDOMAIN attack: This is a type of DNS flood attack where an attacker inundates a DNS server with requests, asking for records that do not exist, in an attempt to cause a denial-of-service for legitimate traffic. This can be accomplished using sophisticated attack tools that can auto-generate unique subdomains for each request. NXDOMAIN attacks can also target a recursive resolver with the goal of filling the resolver's cache with junk requests.

Phantom domain attack: A phantom domain attack has a similar result to an NXDOMAIN attack on a DNS resolver. The attacker sets up a bunch of 'phantom' domain servers that either respond to requests very slowly or not at all. The resolver is then hit with a flood of requests to these domains and the resolver gets tied up waiting for responses, leading to slow performance and denial-of-service.

Random subdomain attack: In this case, the attacker sends DNS queries for several random, nonexistent subdomains of one legitimate site. The goal is to create a denial-of-service for the domain's authoritative nameserver, making it impossible to lookup the website from the nameserver. As a side effect, the ISP serving the attacker may also be impacted, as their recursive resolver's cache will be loaded with bad requests.

Domain lock-up attack: Attackers orchestrate this form of attack by setting up special domains and resolvers to create TCP connections with other legitimate resolvers. When the targeted resolvers send requests, these domains send back slow streams of random packets, tying up the resolver's resources.

Botnet-based CPE attack: These attacks are carried out using CPE devices (Customer Premise Equipment; this is hardware given out by service providers for use by their customers, such as modems, routers, cable boxes, etc.). The attackers compromise the CPEs and the devices become part of a botnet, used to perform random subdomain attacks against one site or domain.

What is DNSSEC?

DNS Security Extensions (DNSSEC) is a security protocol created to mitigate this problem. DNSSEC protects against attacks by digitally signing data to help ensure its validity. In order to ensure a secure lookup, the signing must happen at every level in the DNS lookup process.

This signing process is similar to someone signing a legal document with a pen; that person signs with a unique signature that no one else can create, and a court expert can look at that signature and verify that the document was signed by that person. These digital signatures ensure that data has not been tampered with.

DNSSEC implements a hierarchical digital signing policy across all layers of DNS. For example, in the case of a 'google.com' lookup, a root DNS server would sign a key for the .COM nameserver, and the .COM nameserver would then sign a key for google.com's authoritative nameserver.

While improved security is always preferred, DNSSEC is designed to be backwards-compatible to ensure that traditional DNS lookups still resolve correctly, albeit without the added security. DNSSEC is meant to work with other security measures like SSL/TLS as part of a holistic Internet security strategy.

DNSSEC creates a parent-child train of trust that travels all the way up to the root zone. This chain of trust cannot be compromised at any layer of DNS, or else the request will become open to an on-path attack.

To close the chain of trust, the root zone itself needs to be validated (proven to be free of tampering or fraud), and this is actually done using human intervention. Interestingly, in what's called a Root Zone Signing Ceremony, selected individuals from around the world meet to sign the root DNSKEY RRset in a public and audited way.

Here is a more detailed explanation of how DNSSEC works >>>

What are other ways of protecting against DNS-based attacks?

In addition to DNSSEC, an operator of a DNS zone can take further measures to secure their servers. Over-provisioning infrastructure is one simple strategy to overcome DDoS attacks. Simply put, if your nameservers can handle several multiples more traffic than you expect, it is harder for a volume-based attack to overwhelm your server. Organizations can accomplish this by increasing their DNS server's total traffic capacity, by establishing multiple redundant DNS servers, and by using load balancing to route DNS requests to healthy servers when one begins to perform poorly.

Another strategy still is a DNS firewall.

What is a DNS firewall?

A DNS firewall is a tool that can provide a number of security and performance services for DNS servers. A DNS firewall sits between a user's recursive resolver and the authoritative nameserver of the website or service they are trying to reach. The firewall can provide rate limiting services to shut down attackers trying to overwhelm the server. If the server does experience downtime as the result of an attack or for any other reason, the DNS firewall can keep the operator's site or service up by serving DNS responses from cache.

In addition to its security features, a DNS firewall can also provide performance solutions such as faster DNS lookups and reduced bandwidth costs for the DNS operator. Learn more about Cloudflare's DNS firewall.

DNS as a security tool

DNS resolvers can also be configured to provide security solutions for their end users (people browsing the Internet). Some DNS resolvers provide features such as content filtering, which can block sites known to distribute malware and spam, and botnet protection, which blocks communication with known botnets. Many of these secured DNS resolvers are free to use and a user can switch to one of these recursive DNS services by changing a single setting in their local router. Cloudflare DNS has an emphasis on security (and Cloudflare includes DNS filtering in its SASE platform).

Are DNS queries private?

Another important DNS security issue is user privacy. DNS queries are not encrypted. Even if users use a DNS resolver like 1.1.1.1 that does not track their activities, DNS queries travel over the Internet in plaintext. This means anyone who intercepts the query can see which websites the user is visiting.

This lack of privacy has an impact on security and, in some cases, human rights; if DNS queries are not private, then it becomes easier for governments to censor the Internet and for attackers to stalk users' online behavior.

DNS over TLS and DNS over HTTPS are two standards for encrypting DNS queries in order to prevent external parties from being able to read them.

DNS Security Best Practices

Organizations can improve DNS security through the following measures:

- Keep DNS servers and related software updated.
- Use trusted DNS resolvers and enable DNSSEC validation.
- Restrict access to DNS administration and protect accounts with multifactor authentication.
- Monitor DNS traffic for unusual query patterns.
- Use DNS filtering to block known malicious domains.
- Protect domain registrar accounts and review DNS records regularly.
- Implement DDoS protection and maintain redundant DNS infrastructure.
- Use DNS over HTTPS (DoH) or DNS over TLS (DoT) when appropriate to encrypt DNS communication between a client and its resolver.

DNS and DNSSEC Comparison

Feature	DNS	DNSSEC
Main purpose	Resolves domain names into IP addresses	Adds authenticity and integrity verification to DNS data
Digital signatures	Not inherently provided	Uses cryptographic signatures
Protection against forged records	Not by itself	Helps detect forged data when validation is performed
Encrypts DNS queries	No	No
Guarantees website safety	No	No